

REV	DATA	MOTIVO	ITENS MODIFICADOS
0	19/05/2020	Emissão inicial	Nenhum
1	28/09/2020	Alteração na estrutura organizacional	Itens 3 e 6.1 (revisão de responsabilidades e autoridades)
2	11/10/2021	Adequação à versão NBR ISO/IEC 20000-	Nomenclatura
3	22/11/2021	Alteração na periodicidade do	Item 4, quadro 2.
4	05/10/2022	Ajuste no requisito para seleção de auditor	Item 5, quadro 3.
5	29/09/2023	Adequação à NBR ISO/IEC 27001:2022	Itens 1, 2, 3, 4 (eliminado quadro 2), 5 (eliminado quadro 3), 6, 7 (acrescentada Nota 2), Anexos 1 e 2
6	02/02/2024	Revisão geral	Inserida rotulagem e alterado item 3.
7	14/03/2025	Reaprovação do documento	Nenhum
8	06/02/2026	Reaprovação do Documento	Nenhum

REV	DATA	APROVAÇÃO	
8	06/02/2026	CEO	

Este Documento e a informação nele contida são privativos das empresas Interjato Serviços Ltda e Interjato Telecomunicações Ltda. A reprodução de quaisquer partes deste Documento está condicionada à autorização por parte das organizações.

SUMÁRIO

1. OBJETIVO	2
2. DEFINIÇÕES	2
3. RESPONSABILIDADE E AUTORIDADE	3
4. PROGRAMA DE AUDITORIAS	3
5. SELEÇÃO E AVALIAÇÃO DOS AUDITORES	4
6. EXECUÇÃO DAS AUDITORIAS	4
6.1 Comunicação prévia	4
6.2 Planejamento da auditoria	4
6.3 Condução da auditoria – aspectos gerais	5
6.4 Condução da auditoria – aspectos específicos sobre gestão da configuração	5
7. REGISTROS	6
7.1 Comunicação sobre as auditorias	6
7.2 Plano de auditoria	6
7.3 Registro de Não-Conformidade	6
7.4 Relatório Final da Auditoria	6
8. ACOMPANHAMENTO DAS AÇÕES CORRETIVAS	6
9. DOCUMENTAÇÃO DE REFERÊNCIA	7
10. ANEXOS	7
Anexo 01 – Modelo do Plano da Auditoria	8
Anexo 02 - Modelo do Relatório Final de Auditoria	10

1. OBJETIVO

Estabelecer a sistemática para realização de auditorias internas para verificar se o Sistema de Gestão de Serviços e o Sistema de Gestão de Segurança da Informação estão conforme com o planejado (requisitos da NBR ISO/IEC 20000-1 e NBR ISO/IEC 27001 e requisitos da Interjato Serviços Ltda e Interjato Telecomunicações Ltda.) e está mantido e implementado eficazmente, fornecendo subsídios para melhoria dos processos, produtos, serviços e Sistema de Gestão.

2. DEFINIÇÕES

- **Ação corretiva** - Ação implementada para eliminar as causas de uma não-conformidade existente, defeito ou outra situação indesejável, a fim de evitar sua repetição.
- **Auditado** - É o responsável pela atividade que está sendo auditada.
- **Auditor** - Pessoa com competência para a execução das auditorias internas.
- **Auditor-líder** – Auditor que possui a responsabilidade adicional de coordenar a auditoria

- **Auditoria combinada** - auditoria realizada em um único auditado, em dois ou mais sistemas de gestão.
- **Configuração** – grupo de itens de configuração que trabalham em conjunto para fornecer um serviço de TI, ou uma parte identificável de um serviço de TI.
- **Especialista** – Pessoa com conhecimento técnico específico, que atua para apoiar tecnicamente um auditor.
- **Item de configuração (IC)**– Qualquer componente ou outro ativo de serviço que precise ser gerenciado de forma a entregar um serviço de TI.
- **Não-conformidade** - É o não-atendimento de um requisito especificado
- **SGS** – Sistema de Gerenciamento de Serviços
- **SGSI** – Sistema de Gestão de Segurança da Informação

3. RESPONSABILIDADE E AUTORIDADE

As responsabilidades e autoridades para as ações deste procedimento são as seguintes:

Ação	Responsabilidade	Autoridade
Gerenciamento das Auditorias Internas.	Gerente de SOC e Suporte	Diretor Técnico
Definição do programa de auditorias	Gerente de SOC e Suporte	Diretor Técnico
Execução e registro das auditorias internas	Auditores qualificados	
Coordenação da auditoria	Auditor-líder	
Definição e implementação das ações corretivas decorrentes de não-conformidades	Auditados	

Quadro 1 – Responsabilidades e autoridades

4. PROGRAMA DE AUDITORIAS

O intervalo máximo para realização das auditorias internas, tanto no SGS quanto no SGSI será de 12 meses.

Podem ocorrer auditorias extras como parte da resposta a eventos específicos (por exemplo, incidentes de segurança da informação).

Para melhor acompanhamento, todas as auditorias serão indexadas pelo código AI - **xx/yyyy**, onde **xx** é o número sequencial de ocorrência e **yyyy** é o ano de realização.

5. SELEÇÃO E AVALIAÇÃO DOS AUDITORES

Os Auditores são considerados qualificados se atenderem aos critérios apresentados no quadro 2:

- Conhecimento sobre segurança da informação e temas associados ao SGS e SGSI, tais como gestão de riscos, gestão da configuração, proteção de dados pessoais etc.
- Conhecimento sobre os requisitos das normas ISO/IEC 20000-1 e/ou 27001, na sua versão mais atual
- Escolaridade mínima: ensino médio
- Conhecimento das técnicas de auditoria

A designação do Auditor-líder é feita por ocasião da elaboração do Plano da auditoria.

Caso não haja disponibilidade de auditores qualificados e/ou por decisão da Diretoria, poderão ser contratados auditores externos, desde que atendam aos requisitos de qualificação.

A auditoria também pode ser realizada por um auditor qualificado e especialistas nas áreas específicas (por exemplo: gestão da configuração e segurança da informação)

6. EXECUÇÃO DAS AUDITORIAS

A execução das Auditorias Internas é feita através dos seguintes passos:

6.1 Comunicação prévia

Com antecedência de, no mínimo, 3 dias úteis, a auditoria deverá ser comunicada às áreas que serão auditadas e aos envolvidos, pelo meio de comunicação que for mais conveniente. A notificação deve incluir informações sobre:

- Escopo da Auditoria
- Datas e horários
- Equipe Auditora

6.2 Planejamento da auditoria

As auditorias poderão ser realizadas de modo separado (uma para cada sistema de gestão) ou de forma combinada.

O Auditor-líder deverá preparar um Plano de Auditoria, conforme modelo apresentado no Anexo 01, distribuindo as tarefas entre a equipe, de modo que o tempo reservado seja suficiente para atingir os objetivos da auditoria. No caso específico das verificações relacionadas à NBR ISO/IEC 27001, convém consultar o Anexo A da NBR ISO/IEC 27007.

O Auditor-líder deverá verificar previamente se alguma evidência de auditoria não estará disponível para análise crítica pela equipe de auditoria, por exemplo, porque as evidências contêm

dados pessoais ou outras informações confidenciais/sensíveis e, caso isso ocorra, avaliar se o(s) sistema(s) de Gestão pode(m) ser adequadamente auditado(s) na ausência de evidência de auditoria.

Se a conclusão for de que não é possível auditar adequadamente o(s) sistema(s) de Gestão, sem analisar criticamente as evidências identificadas de auditoria, o Auditor-Líder deve informar à Direção Técnico de que não é possível que a auditoria ocorra até que acordos de acesso apropriados sejam concedidos ou meios alternativos para realizar a auditoria sejam propostos para ou pelo auditado.

6.3 Condução da auditoria – aspectos gerais

O início da coleta de evidências deve ser precedido de uma reunião inicial, onde os auditores devem confirmar (ou ajustar) as informações fornecidas na notificação e combinar quaisquer outras providências que julgarem necessárias.

Os trabalhos de análise e julgamento das evidências coletadas durante o exame da documentação, registros e condições nas áreas de interesse, deverão verificar a adequação do Sistema de Gestão das empresas Interjato Serviços Ltda e Interjato Telecomunicações Ltda à NBR ISO/IEC 20000-1, NBR ISO/IEC 27001 e o efetivo cumprimento das definições constantes nos documentos normativos e planejamentos relacionados.

Normalmente, a equipe de auditoria utilizará amostragem para solicitar evidências pertinentes a seus questionamentos. Estas evidências incluirão informações documentadas, constatações da infraestrutura física e entrevistas. Após o uso de evidências documentais, a equipe deverá devolver arquivos e/ou documentos utilizados aos auditados.

Ao final dos trabalhos, a equipe auditora deve realizar uma reunião final com os envolvidos para relato das eventuais não-conformidades, dos pontos positivos e das conclusões e recomendações.

6.4 Condução da auditoria – aspectos específicos sobre gestão da configuração

Além de seguir o item 6.2, a auditoria na área gestão da configuração deve observar as seguintes diretrizes:

- A abrangência da auditoria de gestão da configuração deve incluir pelo menos:
 - Confirmação entre o status de configuração e a situação funcional e/ou física dos Itens de Configuração;
 - Normas internas relacionadas à gestão da configuração;
 - Cumprimento de requisitos contratuais e/ou legais específicos aplicáveis que tratam da gestão da configuração;
 - Tratamento de não-conformidades relacionadas à gestão da configuração;

- Tratamento de pendências da última auditoria interna de gestão da configuração.

7. REGISTROS

Os registros das auditorias internas serão compostos por:

7.1 Comunicação sobre as auditorias

Ver item 6.1 deste procedimento

7.2 Plano de auditoria

Ver item 6.2 deste procedimento

7.3 Registro de Não-Conformidade

O Registro de Não-conformidade deverá ser preenchido pelo auditor que identificou a não-conformidade. A descrição deverá permitir o claro entendimento por parte do auditado, que deverá continuar o preenchimento, analisando as causas e propondo as ações corretivas pertinentes. Para tanto, devem ser seguidas as regras do **PG-06** (Tratamento de oportunidades de melhoria e não-conformidades).

7.4 Relatório Final da Auditoria

Este registro consolida as informações resultantes da auditoria, conforme modelo apresentado no anexo 02.

Nota 1: Caso a auditoria interna seja realizada por entidades externas, os registros de auditoria não precisam seguir os modelos mencionados nos itens 7.2, 7.3 e 7.4, desde que contenham os mesmos tipos de informação.

Nota 2: De forma a preservar a confidencialidade sobre as constatações da auditoria, o relatório final da auditoria deverá ser enviado à Diretoria, que decidirá sobre quem deverá ter acesso aos resultados.

8. ACOMPANHAMENTO DAS AÇÕES CORRETIVAS

Todas as não-conformidades detectadas nas auditorias internas devem ser solucionadas mediante ações corretivas propostas e implementadas em tempo hábil pelos auditados.

Os auditores e/ou auditados devem acompanhar a eficácia das ações corretivas, registrando este acompanhamento e os resultados decorrentes das ações nos registros de Não-conformidade.

Para acompanhamento da implementação, é necessário ter evidências da realização das ações propostas. O acompanhamento da eficácia deverá ser feito após um tempo suficiente para verificar se a não-conformidade não voltou a se repetir.

A Auditoria é considerada concluída quando todas as não-conformidades detectadas forem

9. DOCUMENTAÇÃO DE REFERÊNCIA

NBR ISO/IEC 20000-1

NBR ISO/IEC 27001

NBR ISO/IEC 27007

10. ANEXOS

Anexo 01 – Modelo do Plano de Auditoria

Anexo 02 – Modelo do Relatório de Auditoria

(*) ao mencionar a cláusula, indicar qual norma (NBR ISO/IEC 20000-1 ou NBR ISO/IEC 27001)

Anexo 02 - Modelo do Relatório Final de Auditoria

RELATÓRIO DE AUDITORIA INTERNA

IDENTIFICAÇÃO:

Auditoria Nº:	Processos Auditados:		
NBR ISO/IEC 20000-1 NBR ISO/IEC 27001	Período:		
Setor(es) Responsável (eis):			
Equipe Auditora: Auditor-(L)íder:			
(A)uditor:			

DOCUMENTAÇÃO DE REFERÊNCIA UTILIZADA:

PESSOAS ENTREVISTADAS

RESULTADOS

Pontos positivos
Oportunidades de melhoria - Comentário geral dos auditores:

Não-conformidades N^{os}:

(vide registros específicos)

Orientações para a próxima auditoria:

Com base nos resultados obtidos, é requerido para a próxima auditoria:

Antecipar período de execução

Aumentar ênfase e/ou amostragem nas seguintes áreas:

Verificar a eficácia das não-conformidades N^{os}:

Conclusão da Auditoria: